

Media Protection (MP) — CMMC Level 1

MP.L1-3.8.3 · Control Readiness Sheet

0. Control Identity

Practice	“Sanitize or destroy system media containing FCI before disposal or release for reuse.”
Level / Protects	Level 1 · FCI (Federal Contract Information), not CUI
Source	FAR 52.204-21(b)(1)(vii) · NIST SP 800-171 3.8.3
Objectives	[a] media is sanitized or destroyed before disposal; [b] media is sanitized before release for reuse

1. Intent

Media that has held FCI can still contain recoverable data even after a file is “deleted.” Before any media leaves your control — discarded, recycled, sold, returned, or reassigned — the FCI on it must be wiped or destroyed (this includes internal drives, USBs, phones, the storage inside printers and copiers, and paper).

2. Ownership

Responsible	IT Administrator / IT Asset Manager — performs the wipe or destruction and handles reassignment.
Accountable	IT Manager / Head of IT — owns the outcome (collapses to owner/operations lead in a very small firm).

Tailor per client — titles flex; the rule that doesn't is that every control has one named, accountable owner.

3. Assessment — how an assessor audits it

- **Examine:** sanitization/disposal policy; destruction logs and vendor certificates; asset-disposal tracking.
- **Interview:** IT/asset staff on how media is wiped or destroyed and how reuse is handled.
- **Test:** witness a wipe or verify a destruction method (obj. a); confirm reused media is wiped before re-issue (obj. b).

4. Evidence to Have Ready

Sanitization/disposal policy · destruction log (date, asset, method, who) · vendor certificates of destruction · method aligned to NIST SP 800-88 · disposal-vendor SLA.

5. Customer Questions

- What media holds, or has held, FCI — computers, drives, USBs, phones, printers/copiers, paper?
- When a device is retired or reassigned, what happens to the data — wipe, degauss, or destroy? Who does it?
- Do you keep records or certificates of destruction?

6. Not Applicable — Determination

Eligibility: Effectively never — applies wherever any media holds FCI (endpoints and paper included). Default to MET.

If ever justified: “MP.L1-3.8.3 is Not Applicable. Within the assessment boundary, FCI is never stored on any media capable of sanitization or destruction [state basis], as evidenced by [artifact]. This determination is re-evaluated if that changes.”

Common pitfall: “Delete” is not sanitize — and don't overlook the hard drives inside printers/copiers, or paper FCI. These are the most-missed media types.

7. Commercial Framework Mapping

Framework	Equivalent control(s)	Called
SOC 2 (TSC)	CC6.5 — protections over assets discontinued only after data is unrecoverable; CC6.7 — controls movement/removal of information	"Data disposal"
ISO 27001:2022	A.7.10 Storage media · A.7.14 Secure disposal or re-use of equipment · A.8.10 Information deletion	"Secure disposal / re-use"

Gap: Low. Same concept as MP.L1-3.8.3 — what's new commercially is that it extends to cloud/SaaS data deletion, and a SOC 2 auditor wants evidence the control operated across the whole review period, not just that it exists today.